TSYP14 · CITY BRAIN CONVERGENCE · TEAM NEXAGUARD

Guardian

The trust layer of the smart city

“Is this data telling the truth?”

How it works · what it protects · how we prove it



WHY GUARDIAN EXISTS

One fake reading can open a floodgate

Spoofed sensor
A hacked device reports a flood that isn't there

Replay
An old, genuine message is sent again

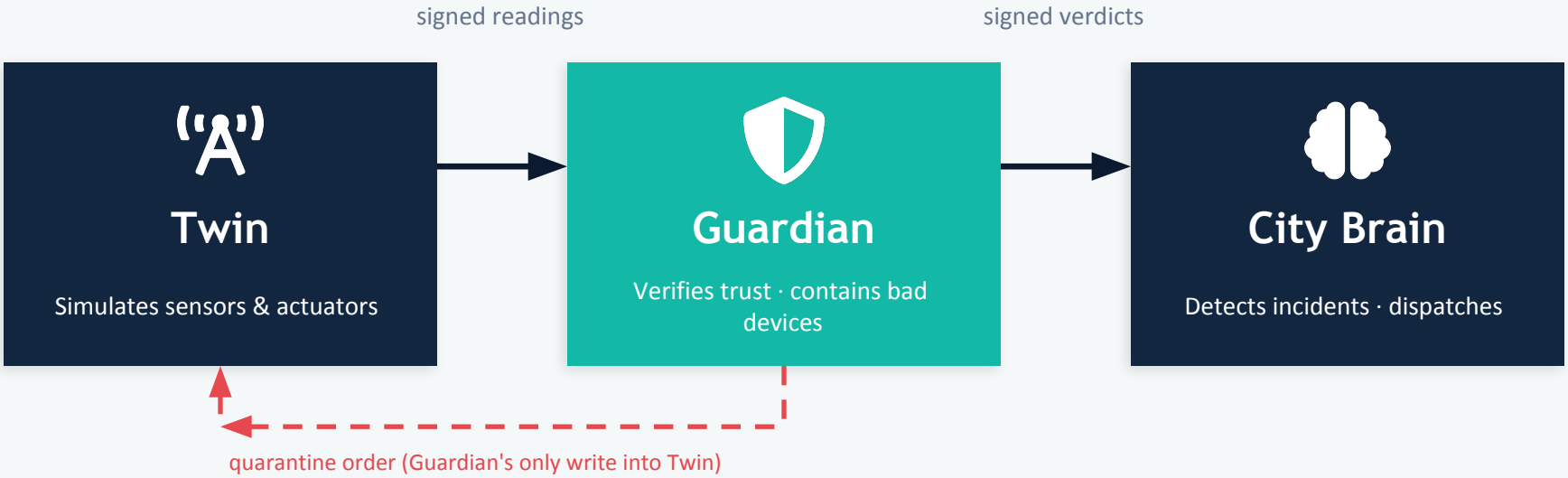
Tampering in transit
A value is changed between Twin and Brain

Stuck sensor
A broken device repeats the same value



THE TRIPLET

Where Guardian sits in the triplet



Transport: MQTT for the event stream · JSON-RPC 2.0 over HTTPS/WebSocket for Guardian's tools · mTLS between every layer

ITS JOB

What Guardian does, in four verbs



1. Consume

Subscribes to every Twin event on twin/events/#



2. Score

Runs a 6-step pipeline and gives each reading a trust score from 0 to 1



3. Publish

Signs every verdict and broadcasts it to all layers over MQTT



4. Contain

Quarantines a device after 3 consecutive rejected readings

DETECTION PIPELINE

Every reading passes 6 checks, in order

1

Schema + signature

Right fields? Twin's HMAC signature valid?

2

Replay

event_id seen before? seq not increasing?

3

Plausibility

Physically possible? Range, unit, speed of change

4

Anomaly score

EWMA z-score vs this device's normal behaviour

5

Verdict

Score mapped to trusted / suspicious / rejected

6

Sign & publish

Ed25519 signature, store, publish, audit log

Steps 1–3 short-circuit: any failure means "rejected" and the pipeline stops.

Steps 4–6 score and prove: the verdict is signed so nobody can forge it.

SCORING

Three verdicts, one trust score



Rejected

Blocked. City Brain must not act on it. Counts toward quarantine.

Suspicious

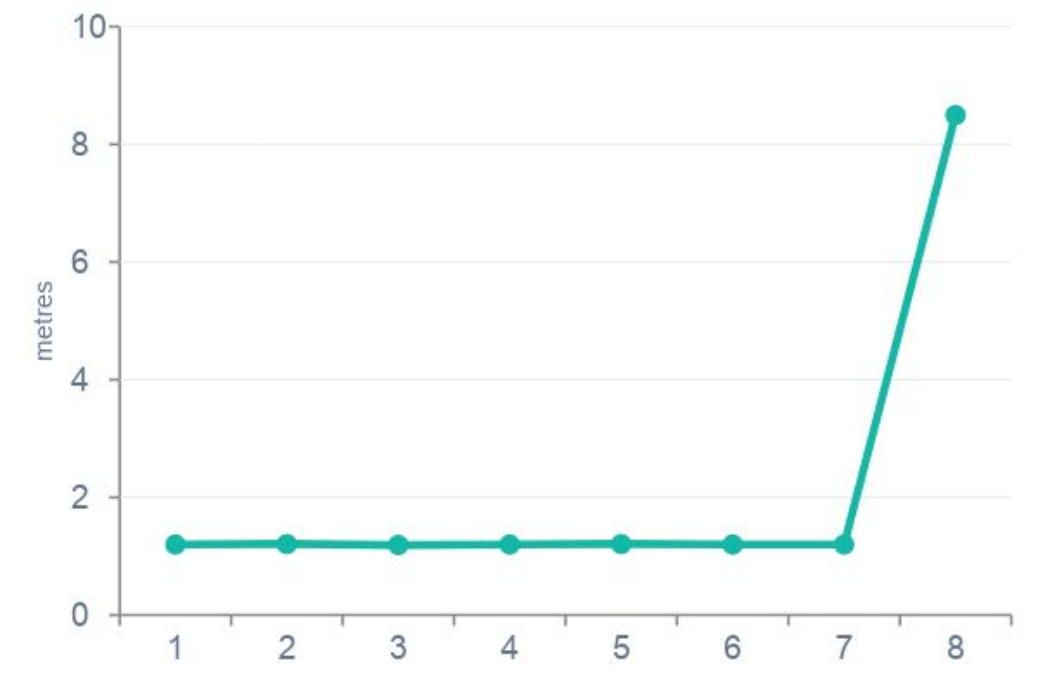
Logged and flagged — never auto-blocked. Example: a sensor stuck on one value for 5 min.

Trusted

Normal behaviour. The City Brain can act on it.

SCENARIO G2

Live example: catching a fake flood



1.46 m/s

observed rise — physical max is 0.05 m/s (~30× too fast)

- Signature valid — the sensor itself is compromised
- Step 3 (plausibility) rejects it
- 3 rejects in a row → device quarantined in under 10 s
- City Brain never opens the floodgate

CONTAINMENT

Three strikes and the device is isolated



Reject 1

counter = 1

Reject 2

counter = 2

Reject 3

QUARANTINE

release_device

admin only, audited

What Guardian does

- Marks device quarantined + audit entry
- Sends a signed, retained order to Twin
- Sends a rollback advisory to City Brain

What Twin must do

- Verify Guardian's signature first
- Refuse commands: DEVICE_QUARANTINED
- Keep sending telemetry, acknowledge, never self-release

SECURITY

Five locks, each with its own test

mTLS

No certificate from the triplet CA, no connection. The certificate must match the token's role.

JWT per tool call

One token = one tool, one use, ≤120 s. A City Brain token cannot call release_device.

Twin signature

HMAC-SHA256 on every event; one changed digit breaks it.

Guardian signature

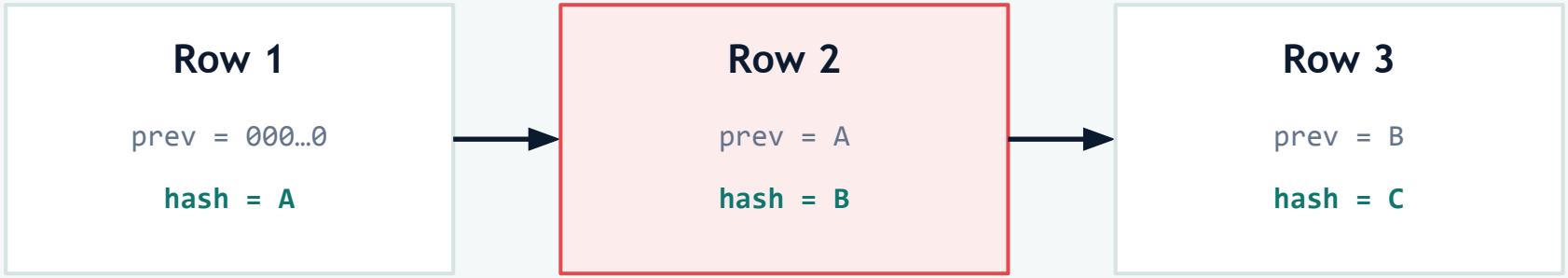
Ed25519 on every verdict and order — a forged "trusted" is detected.

Hash-chained audit log

Append-only. Editing any past row breaks the chain.

AUDIT LOG

How we prove nobody rewrote history




```
this_hash = sha256(prev_hash + canonical_json(row))
```

Edit row 2 → its hash no longer matches B. Recompute B → row 3's prev no longer matches. Database triggers also block UPDATE, DELETE and TRUNCATE.

INTERFACE

How the other layers talk to Guardian

JSON-RPC tool	Returns	Who may call
get_trust_verdict	event_id, trust_score, verdict, reason (signed)	City Brain, admin
get_device_status	trusted | suspicious | quarantined	Everyone
release_device	status — always written to the audit log	Admin only
health	ok | degraded	Everyone

Full contract with real JSON examples: guardian/INTERFACE.md (v1.1)



Shared timeline screen

- Push: MQTT triplet/timeline/guardian
- Pull: GET /timeline
- Every verdict, status change, quarantine and release
- Plain JSON — works with any UI

EVIDENCE

Proven by tests and the Test Book

62
automated tests passing

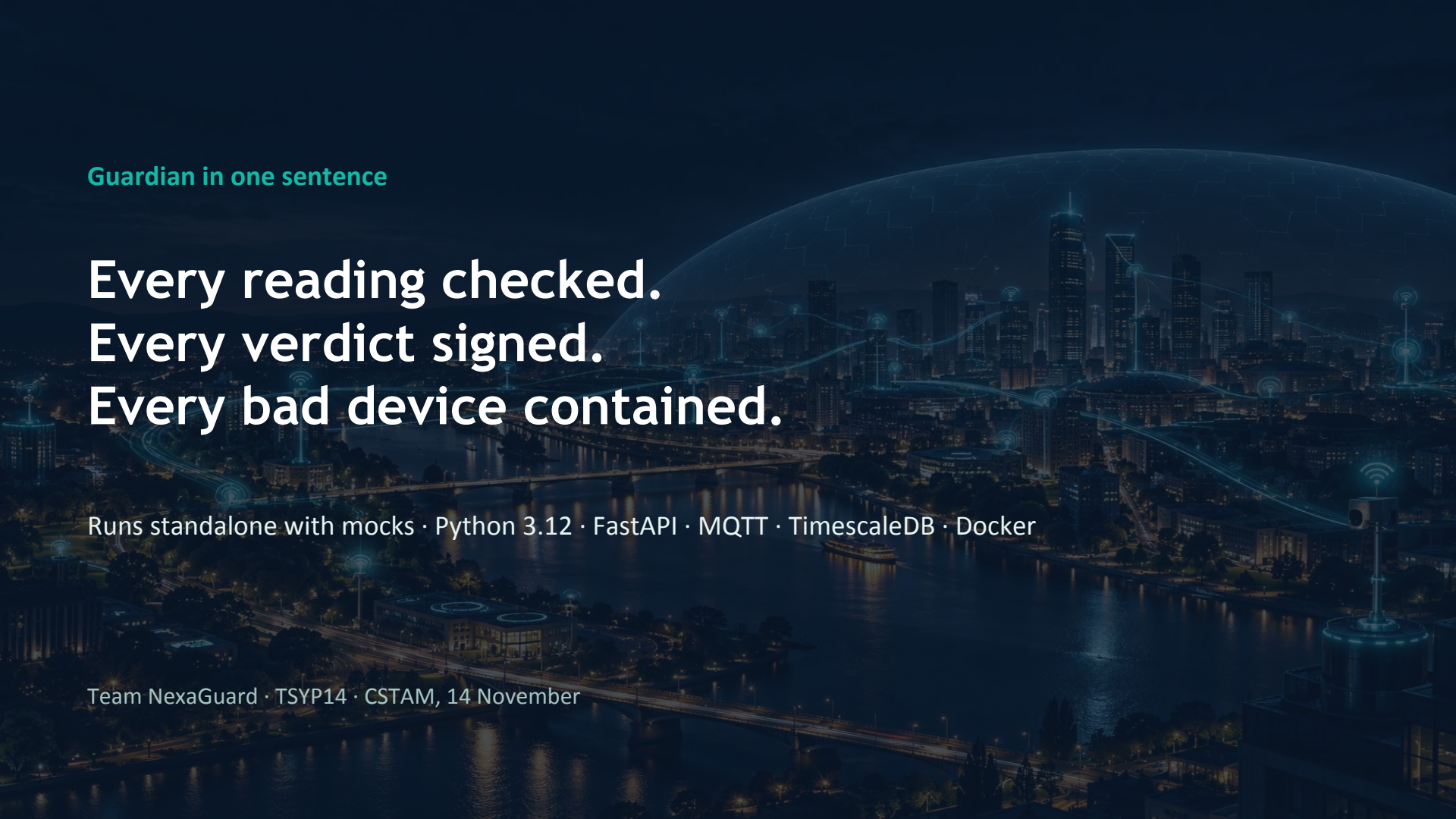
5 / 5
Test Book scenarios pass

< 10 s
fake flood → isolation

Test suites: unit (each pipeline step), contract (vs mocks), adversarial (spoofing, replay, MITM, real mTLS server).

Still to confirm: full Docker run and green CI on GitHub.

G1	**Stuck sensor** → suspicious, not blocked
G2	**Spoofed flood** → rejected + isolated < 10 s
G3	**Replay attack** → 2nd copy rejected
G4	**Brain ignores fake** → no dispatch
G5	**Quarantine mid-flow** → Twin refuses commands



Guardian in one sentence

Every reading checked.
Every verdict signed.
Every bad device contained.

Runs standalone with mocks · Python 3.12 · FastAPI · MQTT · TimescaleDB · Docker

Team NexaGuard · TSYP14 · CSTAM, 14 November